

```

"HOME": "/home/jatin",
"LC_CTYPE": "en_US.UTF-8",
"BROWSER": "/usr/bin/chromium",
"JOURNAL_STREAM": "8:20822",
"XDG_SESSION_TYPE": "x11",
"XDG_SESSION_DESKTOP": "gnome-xorg",
"GJS_DEBUG_OUTPUT": "stderr",
"RBNV_DIR": "/home/jatin/Area_51/sinatra_example",
"MAIL": "/var/spool/mail/jatin",
"WINDOUPATH": "2",
"TERM": "xterm-256color",
"SHELL": "/usr/bin/zsh
}

```

Sinatra can handle views and templates as well, and they are pretty simple. So, it's good if you want to make user-facing applications.

 **Note:** Most of the code used in the article is also available at https://github.com/jatindhankhar/sinatra_example.

Continued from page 37...

dangerous, leaving a network or application susceptible to attack, while giving an illusion that everything is alright. It has been observed that automated tools tend to exhibit false positives as well as false negatives. This brings us to the next important question of which method is better—the automated VAPT or manual VAPT?

Automated vs manual VAPT

The shortest answer is that the manual VAPT is always better and, hence, is a more widely used approach. This is because the automated tools are based on simple logic, which checks either for signatures or behaviour. To understand this, let's go to the basic difference between a software program and the human mind. Listed below are the steps a typical ethical hacker performs for a VAPT.

- Enumerates a vulnerability
- Performs an attack manually
- Analyses the results of the attack
- Performs similar or different attacks based on previous findings
- Assimilates the results to create a customised attack
- Exploits the vulnerability further to see if more attacks are possible
- Repeats the above steps for all vulnerabilities

Each network or application is different, resulting in a very wide range of vulnerability scenarios. From the above steps, it becomes clear that there is a lot of complexity involved in VAPT, wherein, the results of one test decide the actions of the next one. This makes VAPT a process of

Plugins and libraries

There are innumerable libraries available for Ruby, in general, and almost of all them will work with Sinatra but there are some, like those listed below, that are a 'must have'.

Shotgun: It lets you reload the server on file changes, enabling faster development.

Byebug: This library lets you debug an issue by pausing the request and providing a full-blown REPL to investigate.

Sinatra-Cross-Origin: This library lets you handle Cross Domain Origin Resource Sharing (CORS), which is very useful if you are making a web SDK for others to use.

There are many extensions available at <http://www.sinatrarb.com/extensions-wild.html> that might help.  

References

- [1] <http://www.sinatrarb.com>
- [2] <https://sinatrarb.slack.com> - Sinatra Slack Community

By: Jatin Dhankhar

The author loves modern C++, Ruby, JavaScript and Haskell. He can be reached at jatin@jatindhankhar.in.

cascaded intelligence, where you cannot predict the next step and also need to apply years of experience to reach a conclusion. No tool can do this, at least, not as of today, and hence it must be performed manually. An ethical hacker's job can be made less stressful by automating certain tasks of vulnerability assessment; however, the proof-of-concept part in penetration testing mostly relies on manual ways of exploiting the loophole and gathering the required evidence. Given below are the benefits of manual penetration testing.

- Mimics the behaviour of real life hackers
- Brings a great deal of accuracy to the results
- No false positives
- Provides evidence, enabling the replication of problems
- Helps in fixing a product's security design issues

VAPT is a methodical approach to risk management. CISO's or IT heads should, as a matter of strategy, incorporate VAPT in their budgets and risk governance processes. It should be a periodically executed process, and the frequency should depend upon the data's confidentiality and risk impact. While there are multiple tools to perform vulnerability assessment, penetration testing is a manual process, and should be handled by professional and highly experienced ethical hackers. This will ensure genuine cyber security as opposed to an illusion of being secure.  

By: Prashant Phatak

The author is the founder CEO of Valency Networks, based in India (www.valencynetworks.com). He is a subject matter expert in IT security penetration testing, designing and audits. He can be reached at prashant@valencynetworks.com.